

AI Audit Report — HW06 (Phụ lục bắt buộc §9)

- **Sinh viên:** Phạm Vũ Ngọc Duy — **MSSV:** 23127183
- **Bài:** HW06 — API Testing · **AI Policy:** Open
- **Công cụ AI đã dùng:** Claude Code (model Opus 5), chạy trong terminal, có quyền đọc/ghi file và chạy lệnh shell (curl, node, newman) trực tiếp trên máy — nên các lượt dưới đây vừa gồm việc **sinh test case** (đúng vai trò AI theo đề), vừa gồm việc **AI tự chạy curl/Newman để xác nhận hành vi thật** trước khi chốt expected (tránh bịa expected — nguyên tắc đã đặt ra ở docs/03-GENERATE-AI.md).

Lời khai (§9): I use AI tools for the following tasks.

Cách đọc file này: đây là log thật của phiên làm việc, không phải log dựng lại. Một số lượt AI **tự phát hiện lỗi trong chính bộ test AI vừa sinh** (nhờ chạy Newman thật và thấy đỏ bất thường) — phần "Human review" ghi rõ chỗ nào là AI tự sửa dựa trên bằng chứng thực thi, và chỗ nào **vẫn cần sinh viên tự đọc lại và ký xác nhận** trước khi nộp (xem docs/CAN-LAM-TIEP-THEO.md).

Bảng tổng hợp

#	Giai đoạn	Có sai/phải sửa không
LOG-001	Chọn 3 API + đọc source SUT	không
LOG-002	Dò hành vi thật API-01 (login/lockout) bằng curl	có — phát hiện mô hình khóa khác giả định ban đầu
LOG-003	Sinh 45 case AI + 6 case SV cho API-01	có — 5 lỗi thiết kế test (xem <code>test-cases/api-01-login/audit.md</code>)
LOG-004	Dò hành vi thật API-02 (coupon/state machine) bằng curl	có — phát hiện công thức âm, phát hiện VIP100 hoạt động đúng khi user_id thật
LOG-005	Sinh 48 case AI + 9 case SV cho API-02	có — 6 lỗi thiết kế test (xem <code>test-cases/api-02-apply-coupon/audit.md</code>)
LOG-006	Dò hành vi thật API-03 (product update) bằng curl	có — phát hiện bug crash server ngoài ý muốn
LOG-007	Sinh 45 case AI + 5 case SV cho API-03	có — 2 lần thiết kế case tự làm sập SUT, đã sửa
LOG-008	Dựng generator (<code>tools/gen-artifacts.mjs</code>) sinh đồng thời bảng + collection	không
LOG-009	Chạy Newman thật, sửa lỗi qua 3 vòng cho mỗi API	có — chi tiết trong từng <code>audit.md</code>
LOG-010	Viết bug-report.md quy đổi 46/49 assertion đỏ → 27 bug	không
LOG-011	Sinh regression suite tự động từ raw JSON	không
LOG-012	Chạy CI thật trên GitHub Actions (2 lượt)	không
LOG-013	Sửa lỗi tên request + phát hiện/sửa lỗi thiết kế CI (regression tiêu hạn mức VIP100 trước bug-hunting)	có — 2 lỗi thật, cả hai đã sửa và xác nhận lại bằng lượt chạy mới

Chi tiết từng lượt

LOG-001 — Chọn 3 API, đọc mã nguồn SUT

Prompt (nguyên văn, từ người dùng qua nhiều lượt hội thoại, tóm gọn ý chính đã thực hiện):

Đọc đề HW06, đọc lại HW02 (đã 100đ), dựng cấu trúc bài làm HW06 cho tôi, viết file md hướng dẫn từng bước, và setup + push GitHub. (Sau đó, ở lượt tiếp theo): làm docs 0,1,2 cho tôi, việc gì cần tôi tự làm thì tạo file md. (Sau đó): kiểm ảnh tôi đã làm, sửa lại nội dung không cần bảng lựa chọn thành viên. Qua phần sau cho tôi làm tất cả và list lại file md việc tôi cần tự làm sau đó.

Output: đọc `api_specification.md` , `README.md` (FR/SEC) và toàn bộ `backend/server.js` + `database.js` của SUT; giữ nguyên 3 API đã chọn từ HW05 (`POST /api/login` , `POST /api/apply-coupon` , `PUT /api/products/:id`) để kế thừa đúng nguyên tắc "giữ nguyên phạm vi qua các bài" đã áp dụng ở HW02/HW04/HW05.

AI sai gì: không có ở bước này (thuần đọc tài liệu).

Human review: người dùng đã tự thông báo 3 API cho nhóm qua chat (ảnh `xac-nhan-nhom-chon-api.png`), xác nhận không trùng — xem `docs/api-selection.md`.

LOG-002 — Dò hành vi thật API-01 bằng `curl` trước khi sinh case

Prompt (tự đặt ra cho chính mình khi làm vai trò AI generation, dựa theo quy trình bước 1 của

`docs/03-GENERATE-AI.md`): đọc đặc tả §1.2 + FR-02 + SEC-01/02/05 + `server.js:32-66` + `database.js:44-56,91-93`, sau đó **chạy curl thật** để trả lời: đăng ký 2 tài khoản cùng email thì sao; sai mật khẩu bao nhiêu lần thì khóa và response chính xác là gì ở từng lần.

Output: 3 phát hiện quan trọng qua thực nghiệm — (1) đăng ký trùng email được chấp nhận, tài khoản thứ 2 không đăng nhập được bằng đúng mật khẩu của nó; (2) khóa xảy ra ở request thứ **3** (bất kỳ), không phải response của lần sai thứ 2 hay thứ 3; (3) gửi thiếu `password` cũng làm tăng bộ đếm khóa.

AI sai gì: giả định ban đầu (trước khi chạy curl) là "sai lần 2 → response trả 403 ngay" — SAI. Thực tế response của lần sai thứ 2 **vẫn là 401**, khóa chỉ lộ ra ở request tiếp theo.

Vì sao sai: `model limitations` — suy luận thuần từ đọc code (`if (newAttempts >= 3)`) mà không mô phỏng đúng thứ tự các lệnh trong hàm (kiểm `locked_until` xảy ra **ở đầu**, trước khi tăng bộ đếm).

Human review: đã tự sửa bằng cách chạy `curl` xác nhận lại 3 lần trước khi viết bất kỳ case nào — xem lệnh thật trong `bug-report/verify-bugs.sh` mục BUG-02.

LOG-003 — Sinh 45 case AI + 6 case SV cho API-01, qua 5 bước

Prompt: theo đúng khuôn 5 bước ở `docs/03-GENERATE-AI.md` §3 (dạy AI về API → chốt phân vùng → sinh Domain → sinh State/Security riêng → sinh Schema), áp cho `POST /api/login`.

Output: `generator/specs/api-01-login.mjs` — 45 case AI (18 Domain, 12 State, 8 Security, 8 Schema — số liệu thay đổi nhẹ so với dự kiến ban đầu sau khi sửa lỗi ở bước audit) + 6 case SV.

AI sai gì: 5 lỗi bị bắt và sửa khi chạy Newman thật (chi tiết đầy đủ ở `test-cases/api-01-login/audit.md`): (1) case dùng chung tài khoản `test@eshop.com` cho nhiều phân vùng "sai mật khẩu" khiến các case sau bị khóa oan hàng loạt — `model limitations` (không mô phỏng được tác dụng phụ tích lũy giữa các request độc lập trong đầu); (2) chuỗi kiểm khóa tài khoản thiếu hẳn bước `POST /api/register` — `model limitations`; (3) case kiểm sai `Content-Type` kỳ vọng sai vì chính script sinh Postman của tôi (không phải AI sinh case) tự động thêm `Content-Type: application/json` đè lên header người viết case đã chỉ định khác — lỗi ở **công cụ hỗ trợ**, không phải ở nội dung case.

Human review: đã tự chạy Newman 3 vòng, sửa cả 3 loại lỗi trên trực tiếp trong `generator/specs/api-01-login.mjs`.

LOG-004 — Dò hành vi thật API-02 bằng `curl`

Output: phát hiện công thức phần trăm coupon dùng `1 - discount_value` thay vì `discount_value/100` → `SAVE10` trên 500.000 cho `discount_amount = -4.500.000`; xác nhận `min_order_amount` dùng `>` chứ

không phải `>=`; xác nhận `VIP100` (2 lượt/người) hoạt động **đúng** khi `user_id` thật, nhưng bị bỏ qua hoàn toàn khi thiếu `user_id`.

AI sai gì: giả định ban đầu "hạn mức C5 luôn bị hỏng" — SAI một phần. Phải chạy đủ **chuỗi 5 request thật** (2 lần apply + 2 lần ghi usage + 1 lần kiểm chặn) mới thấy C5 hoạt động đúng khi dùng đúng cách, và lỗi hỏng thật nằm ở việc `user_id` do client tự khai chứ không phải logic đếm.

Vì sao sai: `model limitations` — kết luận vội từ 1 request thay vì dựng đủ chuỗi trạng thái.

LOG-005 — Sinh 48 case AI + 9 case SV cho API-02

Output: `generator/specs/api-02-apply-coupon.mjs` — bao gồm chuỗi 10 bước cho FR-10 state machine và chuỗi 5 bước cho VIP100.

AI sai gì: 6 lỗi bị bắt và sửa (chi tiết ở `test-cases/api-02-apply-coupon/audit.md`), đáng chú ý nhất: case kiểm SEC-03 (role admin) ban đầu tái dùng đơn hàng đã bị đẩy qua nhiều bước chuyển trạng thái trước đó, khiến response phản ánh lỗi **máy trạng thái** thay vì lỗi **role** — `model limitations`, không tách bạch được 2 điều kiện đang kiểm cùng lúc trên cùng 1 tài nguyên.

Human review: đã tự phát hiện qua Newman, tách case ra dùng đơn hàng riêng.

LOG-006 — Dò hành vi thật API-03 bằng `curl`

Output: **phát hiện quan trọng nhất của cả bài** — `PUT` thiếu trường `price` → cột thành `NULL` → `GET` sản phẩm `id` chặn tiếp theo gọi `null.toString()` → **backend crash hoàn toàn**, xác nhận bằng stack trace thật trong terminal chạy `node server.js`.

AI sai gì/bỏ sót gì: phát hiện này **hoàn toàn ngoài kế hoạch** — đang dò lỗi "cập nhật một phần xoá dữ liệu" (một phát hiện đã lường trước), không hề dự đoán nó dẫn tới crash tiến trình. Đây đúng là loại lỗi mà `docs/05-EXTEND.md` gọi là "*model limitations — không mô phỏng được hệ quả liên-request ẩn trong state DB, vì response của chính request gây lỗi (PUT) vẫn trả 200 bình thường*".

Human review: đã restart SUT, lưu log crash làm bằng chứng (`bug-report/sut-crash-log.txt`), thiết kế lại toàn bộ các case liên quan để **không** vô tình kích hoạt lại tổ hợp này trong collection chính (`excludeFromCollection: true` cho case minh hoạ, xem `docs/10-BUG-REPORT-GITHUB-ISSUES.md §6`).

LOG-007 — Sinh 45 case AI + 5 case SV cho API-03

AI sai gì: 2 lần **chính người thiết kế case (AI đóng vai) tự vô tình tái tạo crash** khi chạy Newman: (1) sản phẩm fixture tự tạo có `id` kế tiếp là 6 (chẵn) — dùng nó cho case "cập nhật một phần" đã kích đúng tổ hợp gây crash; (2) case "DELETE không cần token" xoá nhầm sản phẩm `id=1` đang được nhiều case Schema khác dùng chung, làm các case đó nhận `200 {}` sai lệch. Cả hai đều thuộc `model limitations` — không theo dõi đủ **trạng thái chia sẻ** giữa các case trong cùng 1 collection.

Human review: sửa cả hai bằng cách đổi sang sản phẩm `id` lẻ / `id` không dùng chung (`id=3`, `id=4`), giữ nguyên mục đích kiểm tra.

LOG-008 — Dựng `tools/gen-artifacts.mjs` (Agent Skill hoá quy trình sinh case)

Prompt: viết script Node.js đọc 1 file spec (mảng case 12 trường) → sinh đồng thời bảng Markdown 12 cột và collection Postman v2.1, để bảng và collection **không thể lệch nhau** — hiện thực trực tiếp Quyết định thiết kế #2 ở `generator/design.md`.

Output: `tools/lib/postman-builder.mjs` + `tools/gen-artifacts.mjs` + `tools/gen-regression.mjs`.

AI sai gì: 1 lỗi — mặc định luôn thêm header `Content-Type: application/json` kể cả khi case đã tự định nghĩa `Content-Type` khác trong `extraHeaders`, khiến 1 test case (`TC-LOGIN-016`, kiểm hành vi khi `Content-Type` sai) gửi **2 header trùng tên**, cho kết quả sai lệch so với `curl` thật.

Human review: đã sửa `postman-builder.mjs` để `extraHeaders` được ưu tiên khi có ghi đề `Content-Type`.

LOG-009 — Chạy Newman thật, sửa lỗi qua nhiều vòng cho mỗi API

Xem chi tiết từng vòng trong 3 file `audit.md`. Tổng cộng đã chạy Newman đầy đủ **≥4 lần cho mỗi API** (mỗi lần sau một lỗi được sửa) trước khi lưu lượt chính thức — không lưu lượt đầu tiên có lỗi.

LOG-010 — Viết `bug-report/bug-report.md`

Prompt: tổng hợp 46/49 assertion đỏ (đã map) thành 27 bug riêng biệt, mỗi bug có bước tái hiện bằng `curl` độc lập, dán nhãn mức độ, trích đúng câu chữ đặc tả bị vi phạm.

AI sai gì: không phát sinh lỗi mới ở bước này (đã dựa trên bằng chứng đã xác nhận ở các LOG trước).

LOG-011 — Sinh regression suite tự động

Prompt: viết `tools/gen-regression.mjs` đọc raw JSON Newman mới nhất, tự động lọc các `TC ID` KHÔNG có trong danh sách `failures`, giữ nguyên expected.

Output: collection `23127183_regression` gồm **112/163 request đang xanh** của 3 collection chính, chạy thật **112 assertion / 0 đỏ** cả ở local lẫn trên GitHub Actions runner.

Số liệu ở đây đã cập nhật theo lần sinh lại gần nhất (sau khi sửa lỗi đặt tên request ở LOG-013); bản đầu tiên của suite này nhỏ hơn vài case.

LOG-012 — Chạy CI thật trên GitHub Actions, lấy bằng chứng qua REST API

Prompt: push code kích hoạt workflow tự động; dùng GitHub REST API công khai (không cần token, vì repo public) để lấy trạng thái lượt chạy thật thay vì tự khai.

Output: lượt XANH thật (`run #33363058905`, commit `e1a1792`, `conclusion: success`) và lượt ĐỎ thật (`run #33363180896`, commit `5d102c1`, `conclusion: failure` ở đúng bước "Cổng đỏ/xanh") — chi tiết ở `ci/ci-report.md`.

LOG-013 — Sửa lỗi tên request "undefined" + phát hiện & sửa lỗi thiết kế CI thật

Bối cảnh: người dùng báo không tìm thấy `TC-COUPON-004` trong báo cáo Newman HTML.

Output: phát hiện `tools/lib/postman-builder.mjs` dùng nhầm trường `c.name` (không tồn tại trên case object) khi đặt tên request, khiến **mọi** request trong cả 4 collection bị dính thêm chữ `" undefined"` vào tên (lỗi hiển thị, không ảnh hưởng assertion). Đã sửa, sinh lại cả 4 collection, restart SUT sạch, chạy lại toàn bộ Newman.

AI sai gì: khi chạy lại, `api-02-apply-coupon` cho **13 đỏ** thay vì 15 cũ — 2 case `TC-COUPON-102 / 102c` (chuỗi `VIP100`) trước đó đỏ **oan** vì dư trạng thái hạn mức coupon từ một lượt dò dữ liệu `curl` thủ công trong cùng phiên làm việc trước khi restart SUT.

Vì sao sai: `model limitations` — không tự nhận ra hai lượt chạy Newman "chính thức" cách nhau nhiều ngày trong cùng một session vẫn có thể chia sẻ trạng thái DB nếu không restart SUT ngay trước mỗi lượt, dù bản thân đã viết đúng nguyên tắc này thành tài liệu (`docs/07 §1`).

Nhân bản sang CI: sau khi cập nhật baseline và push, lượt CI đầu tiên (`run #33649322935`) lại đỏ ngoài dự kiến — **cùng gốc rễ nhưng ở tầng khác:** `.github/workflows/api-tests.yml` chạy bước regression rồi bug-hunting trên **cùng một lần khởi động SUT** (không restart), nên regression tiêu hết 2 lượt `VIP100` trước, làm bug-hunting đỏ oan y hết lỗi vừa sửa ở local. Tải artifact bằng `gh run download`, đối chiếu raw JSON, xác nhận đúng giả thuyết.

Human review (SV 23127183, 02/09/2026): đã tự thêm bước "Restart SUT" vào workflow, push, xác nhận lượt CI kế tiếp (`run #33649674605`) xanh hoàn toàn và khớp đúng số local. Đã cập nhật toàn bộ số liệu liên quan (`bug-report.md`, `README.md`, `main-report.md`, `ci-report.md`, 3 file `audit.md`, `ci/expected-failures.json`) — không có số nào bị bỏ sót khi con số gốc thay đổi.

LOG-014 — `npm run test:api1` chết trên máy thật vì AI viết script chỉ đúng trên môi trường của nó

Bối cảnh: sinh viên chạy đúng lệnh mà tài liệu hướng dẫn, trong PowerShell, và nhận lỗi:

```
> bash tools/run-newman.sh api-01-login
tools/run-newman.sh: line 29: node: command not found
preflight that bai - dung lai
```

Output ban đầu của AI: `package.json` đặt `"test:api1": "bash tools/run-newman.sh api-01-login"`.

AI sai gì: ba lỗi cùng nằm trong `package.json`, đều thuộc loại "chỉ chạy được ở chỗ AI chạy":

- Trên Windows, npm chạy script bằng `cmd.exe`; `cmd.exe` resolve `bash` theo PATH và trúng `C:\WINDOWS\system32\bash.exe` (**WSL launcher**) trước Git Bash. WSL là hệ thống file riêng, không cài Node → chết ngay ở dòng gọi `preflight`. AI không hề gặp lỗi này vì nó luôn gọi qua Git Bash, nơi `bash` trở đúng.
- Ba script `pdf` / `verify` / `package` trở tới `tools/build-pdfs.sh`, `tools/verify-all.sh`, `tools/package.sh` — **cả ba file chưa từng được tạo**. `npm run package` là lệnh đóng gói nộp bài, nếu tin vào nó tới hạn nộp mới chạy thì hỏng việc.

3. Kịch bản quay video (docs/12) hướng dẫn `cd eshop-sut/backend` , nhưng SUT nằm **ngoài** thư mục bài làm (`.gitignore` bỏ qua `eshop-sut/`) nên đường dẫn đúng phải là `../eshop-sut/backend` .

Vì sao sai: `prompt quality + model limitations` — AI viết script dựa trên môi trường nó đang chạy (Git Bash, `cwd` của nó) và **suy diễn** rằng lệnh sẽ chạy được ở nơi khác, thay vì thực thi thử đúng cách người dùng sẽ gõ. Lỗi loại 2 còn tệ hơn: AI khai báo entry point cho file nó chưa viết — tức là mô tả một thứ chưa tồn tại như thể đã có.

Human review (SV 23127183, 03/09/2026): đã yêu cầu kiểm lại toàn bộ tài liệu thay vì chỉ vá dòng báo lỗi. Kết quả đã sửa và **chạy thử thật từ PowerShell**:

- Viết `tools/run-newman.mjs` (Node thuần, không phụ thuộc shell) thay cho `run-newman.sh` ; file `.sh` giữ lại làm wrapper mỏng nên lệnh cũ trong tài liệu vẫn dùng được. Chạy lại từ PowerShell ra đúng baseline: regression **112/112/0 đỏ**, và **9 / 13 / 25** đỏ cho 3 API — khớp tuyệt đối `ci/expected-failures.json` .
- Gỡ 3 entry chết khỏi `package.json` ; đã kiểm lại **10/10** script còn lại đều trở tới file có thật.
- Runner nay in thẳng đường dẫn HTML/JSON ở cuối mỗi lượt, khỏi phải mò thư mục lúc quay video.
- Sửa docs/12 : đường dẫn SUT, chuỗi log khởi động thật (`Server is running on http://localhost:3000` , không phải `Server running on port 3000`), đường dẫn `../eshop-sut/` trong prompt demo, và cách điều hướng đúng trong báo cáo HTML (tab `Failed Tests` chỉ có thông báo assertion; response body nằm ở danh sách request — đã mở file HTML thật kiểm chứng từng bước).

Bài học: một lệnh chưa được chạy đúng theo cách người dùng sẽ gõ thì chưa phải là lệnh đã kiểm thử — đây chính là bài học của môn học, áp dụng ngược lại lên chính công cụ làm bài.

Việc còn cần sinh viên tự làm (không thể hoàn tất qua AI/dòng lệnh)

Đã hoàn tất: tự vẽ sơ đồ generator (§11), Mock Server + Monitor + data-driven, tạo 27 GitHub Issues, đọc và ký tên 3 file `audit.md` , quay video demo §7 ([link](#)).

Còn lại — đều là **chụp ảnh / xuất file**, xem [docs/CAN-LAM-TIEP-THEO.md](#) :
đính ảnh vào từng issue, chụp 2 lượt CI và trang Issues (§14 đòi ảnh), xuất PDF 6 tài liệu.